

Mobile API Documentation

Version: 1.0

Last updated: 2026-07-06

1. Overview

This document describes the mobile APIs used by the Android and iOS applications.

Base path:

/api/mobile

Authentication:

- Login API does not require a token.
- All other mobile APIs require this header:

Authorization: Bearer <accessToken>

Default content type:

Content-Type: application/json

Multipart APIs use:

Content-Type: multipart/form-data

Security rule:

- The authenticated mobile user can access only the active employee profile mapped to that user.
- Pass `employeeId` in protected APIs.
- If the token user does not match the requested `employeeId`, the API returns an authorization error.

Date and time format:

- Dates use ISO format: `yyyy-MM-dd`
- Date-times use ISO format: `yyyy-MM-dd'T'HH:mm:ss`
- Token expiry timestamps use ISO instant format.

2. Standard Error Response

All mobile API validation and business errors return this format:

```
{
  "code": "VALIDATION_FAILED",
  "message": "Please provide valid request details.",
  "timestamp": "2026-07-06T12:20:30Z",
  "fieldErrors": [
    {
      "field": "mobileNo",
      "message": "Mobile number must be 10 to 15 digits."
    }
  ]
}
```

Common HTTP status codes:

Status	Meaning
200	Success
400	Invalid request or validation failed
401	Missing, invalid, or expired token

403	User is not allowed to access the requested employee
404	Employee, profile, or mapping not found
409	Duplicate email or mobile number
500	Server configuration or unexpected error

3. Endpoint Summary

Feature	Method	Endpoint	Auth Required
---	---	---	---
Login	POST	`/api/mobile/auth/login`	No
Get mapped locations	GET	`/api/mobile/employee-locations?employeeId={employeeId}`	Yes
Get profile	GET	`/api/mobile/profile?employeeId={employeeId}`	Yes
Update email/mobile	PATCH	`/api/mobile/profile/contact`	Yes
Update photo	POST	`/api/mobile/profile/photo`	Yes
Change password	POST	`/api/mobile/profile/password/change`	Yes
Reset password	POST	`/api/mobile/profile/password/reset`	Yes
Check in	POST	`/api/mobile/attendance/check-in`	Yes
Check out	POST	`/api/mobile/attendance/check-out`	Yes
Mark attendance	POST	`/api/mobile/attendance/mark`	Yes
Attendance history	GET	`/api/mobile/attendance/history`	Yes

4. Login

POST `/api/mobile/auth/login`

Use this API to authenticate the mobile app user and receive a bearer token.

Request:

```
{
  "username": "employee@example.com",
  "password": "Password@123"
}
```

Validation:

Field	Required	Rule
---	---	---
`username`	Yes	Max 254 characters
`password`	Yes	Max 128 characters

Success response:

```
{
  "userId": 101,
  "empId": 20,
  "employeeCode": "EMP-020",
  "name": "Rahul Patil",
  "employeeName": "Rahul Patil",
  "email": "employee@example.com",
  "mobileNo": "9876543210",
  "photoUrl": "/uploads/employee-photo/rahul.jpg",
  "designationId": 3,
  "designationName": "Operator",
  "departmentId": 7,
  "departmentName": "Operations",
  "subDepartmentId": 12,
  "subDepartmentName": "Field Team",
  "employeeType": "CONTRACT",
  "reportingManagerId": 44,
  "reportingManagerName": "Manager Name",
  "reportingDepartmentId": 7,
  "reportingDepartmentName": "Operations",
  "roles": [
    "ROLE_EMPLOYEE"
  ],
  "tokenType": "Bearer",
  "accessToken": "eyJhbGciOiJIUzI1NiJ9...",
  "expiresIn": 3600,
  "expiresAt": "2026-07-06T13:20:30Z",
  "loginAt": "2026-07-06T17:50:00",
  "lastLoginAt": "2026-07-05T18:10:00"
}
```

```
}
```

Mobile app action:

- Store `accessToken`.
- Send it in `Authorization: Bearer <accessToken>` for all protected APIs.
- Store `empId`; pass it as `employeeId` in protected APIs.

5. Employee Mapped Locations

GET `/api/mobile/employee-locations?employeeId={employeeId}`

Use this API to get the locations mapped to the authenticated employee.

Headers:

Authorization: Bearer <accessToken>

Query parameters:

Parameter	Required	Description
---	---	---
`employeeId`	Yes	Employee ID returned by login as `empId`

Success response:

```
{
  "success": true,
  "message": "Mapped locations fetched successfully.",
  "employeeId": 20,
  "locations": [
    {
      "locationId": 5,
      "officeName": "Mumbai Office",
      "locationName": "Gate 1",
      "latitude": 19.076,
      "longitude": 72.8777,
      "radiusMeters": 100,
      "displayName": "Mumbai Office - Gate 1"
    }
  ]
}
```

6. Profile

GET `/api/mobile/profile?employeeId={employeeId}`

Use this API to show the latest mobile profile details.

Headers:

Authorization: Bearer <accessToken>

Success response:

```
{
  "success": true,
  "message": "Mobile profile fetched successfully.",
  "userId": 101,
  "employeeId": 20,
  "employeeCode": "EMP-020",
  "name": "Rahul Patil",
  "email": "employee@example.com",
  "mobileNo": "9876543210",
  "photoUrl": "/uploads/employee-photo/rahul.jpg",
  "tokenType": null,
  "accessToken": null,
}
```

```
"expiresIn": null,
"expiresAt": null
}
```

PATCH `/api/mobile/profile/contact`

Use this API to update the user's email address and/or mobile number.

Headers:

```
Authorization: Bearer <accessToken>
Content-Type: application/json
```

Request:

```
{
  "employeeId": 20,
  "email": "new.email@example.com",
  "mobileNo": "9876543211"
}
```

Validation:

Field	Required	Rule
---	---	---
`employeeId`	Yes	Must belong to authenticated user
`email`	No	Must be valid email if provided
`mobileNo`	No	Must be 10 to 15 digits if provided

Business rules:

- At least one value should be changed.
- Email must be unique.
- Mobile number must be unique.
- Updated values are synchronized with user, employee, and onboarding profile records.
- This API returns a refreshed token after contact update. The mobile app should replace the old token with the new one.

Success response:

```
{
  "success": true,
  "message": "Mobile profile updated successfully.",
  "userId": 101,
  "employeeId": 20,
  "employeeCode": "EMP-020",
  "name": "Rahul Patil",
  "email": "new.email@example.com",
  "mobileNo": "9876543211",
  "photoUrl": "/uploads/employee-photo/rahul.jpg",
  "tokenType": "Bearer",
  "accessToken": "eyJhbGciOiJIUzI1NiJ9..",
  "expiresIn": 3600,
  "expiresAt": "2026-07-06T13:20:30Z"
}
```

Common errors:

Code	Meaning
---	---
`INVALID_EMAIL`	Email format is invalid
`EMAIL_ALREADY_EXISTS`	Email is already registered
`INVALID_MOBILE`	Mobile number format is invalid
`MOBILE_ALREADY_EXISTS`	Mobile number is already registered
`PROFILE_UPDATE_NOT_MODIFIED`	No changed value was provided

POST `/api/mobile/profile/photo`

Use this API to update the employee profile photo.

Headers:

Authorization: Bearer <accessToken>
Content-Type: multipart/form-data

Multipart form fields:

Field	Required	Type	Description
---	---	---	---
`employeeId`	Yes	Number	Employee ID
`photo`	Yes	File	Profile photo file

Success response:

```
{
  "success": true,
  "message": "Profile photo updated successfully.",
  "userId": 101,
  "employeeId": 20,
  "employeeCode": "EMP-020",
  "name": "Rahul Patil",
  "email": "employee@example.com",
  "mobileNo": "9876543210",
  "photoUrl": "/uploads/employee-photo/new-photo.jpg",
  "tokenType": null,
  "accessToken": null,
  "expiresIn": null,
  "expiresAt": null
}
```

Common errors:

Code	Meaning
---	---
`PHOTO_REQUIRED`	Photo file was not provided
`ONBOARDING_PROFILE_NOT_FOUND`	Employee onboarding profile is missing
`INVALID_IMAGE`	File could not be stored or validated

7. Password

POST `/api/mobile/profile/password/change`

Use this API when the logged-in mobile user wants to change the password.

Headers:

Authorization: Bearer <accessToken>
Content-Type: application/json

Request:

```
{
  "employeeId": 20,
  "currentPassword": "OldPass@123",
  "newPassword": "NewPass@123",
  "confirmPassword": "NewPass@123"
}
```

Validation:

Field	Required	Rule
---	---	---
`employeeId`	Yes	Must belong to authenticated user
`currentPassword`	Yes	Must match existing password
`newPassword`	Yes	Must follow application password policy
`confirmPassword`	Yes	Must match `newPassword`

Success response:

```
{
  "success": true,
  "message": "Password changed successfully.",
  "userId": 101,
  "employeeId": 20
}
```

Common errors:

Code	Meaning
--- ---	
`CURRENT_PASSWORD_INVALID`	Current password is incorrect
`PASSWORD_CONFIRMATION_MISMATCH`	New password and confirm password do not match
`INVALID_PASSWORD`	New password does not match policy
`PASSWORD_REUSE_NOT_ALLOWED`	New password is same as current password

POST `/api/mobile/profile/password/reset`

Use this API for authenticated password reset from the mobile app.

Important:

- This endpoint currently requires `currentPassword`.
- For "forgot password" without current password, create a separate OTP/token-based API.

Headers:

```
Authorization: Bearer <accessToken>
Content-Type: application/json
```

Request:

```
{
  "employeeId": 20,
  "currentPassword": "OldPass@123",
  "newPassword": "NewPass@123",
  "confirmPassword": "NewPass@123"
}
```

Success response:

```
{
  "success": true,
  "message": "Password reset successfully.",
  "userId": 101,
  "employeeId": 20
}
```

8. Attendance

Attendance APIs support both multipart image upload and JSON Base64 image upload.

Allowed JSON image formats:

- Raw Base64 string.
- Data URI format: `data:image/jpeg;base64,<base64>` or `data:image/png;base64,<base64>`.

Allowed image content types for JSON upload:

- `image/jpeg`
- `image/png`

POST `/api/mobile/attendance/check-in`

Use this API to mark check-in.

Headers:

Authorization: Bearer <accessToken>

JSON request:

```
{
  "employeeId": 20,
  "latitude": 19.076,
  "longitude": 72.8777,
  "locationAddress": "Mumbai Office Gate 1",
  "imageBase64": "...",
  "imageFileName": "check-in.jpg",
  "imageContentType": "image/jpeg"
}
```

Multipart form fields:

Field	Required	Type
employeeId	Yes	Number
latitude	Yes	Decimal
longitude	Yes	Decimal
locationAddress	No	Text
image	Yes	File

Success response:

```
{
  "success": true,
  "message": "Check-in marked successfully.",
  "attendanceId": 501,
  "employeeId": 20,
  "employeeCode": "EMP-020",
  "attendanceDate": "2026-07-06",
  "checkInTime": "2026-07-06T09:35:00",
  "checkOutTime": null,
  "attendanceSource": "MOBILE_APP"
}
```

POST `/api/mobile/attendance/check-out`

Use this API to mark check-out.

Headers:

Authorization: Bearer <accessToken>

JSON request:

```
{
  "employeeId": 20,
  "latitude": 19.076,
  "longitude": 72.8777,
  "locationAddress": "Mumbai Office Gate 1",
  "imageBase64": "...",
  "imageFileName": "check-out.jpg",
  "imageContentType": "image/jpeg"
}
```

Multipart fields are the same as check-in.

Success response:

```
{
  "success": true,
  "message": "Check-out marked successfully.",
  "attendanceId": 501,
  "employeeId": 20,
}
```

```
"employeeCode": "EMP-020",
"attendanceDate": "2026-07-06",
"checkInTime": "2026-07-06T09:35:00",
"checkOutTime": "2026-07-06T18:10:00",
"attendanceSource": "MOBILE_APP"
}
```

POST `/api/mobile/attendance/mark`

Use this API when the app wants one common endpoint for check-in and check-out.

Headers:

Authorization: Bearer <accessToken>

JSON request:

```
{
  "attendanceFlag": "CHECK_IN",
  "employeeId": 20,
  "latitude": 19.076,
  "longitude": 72.8777,
  "locationAddress": "Mumbai Office Gate 1",
  "imageBase64": "...",
  "imageFileName": "attendance.jpg",
  "imageContentType": "image/jpeg"
}
```

Accepted attendance flag values:

- `CHECK\_IN`
- `CHECK\_OUT`
- `CHECKIN`
- `CHECKOUT`
- `IN`
- `OUT`

Multipart form fields:

Field	Required	Type
attendanceFlag	No	Text
flag	No	Text
employeeId	Yes	Number
latitude	Yes	Decimal
longitude	Yes	Decimal
locationAddress	No	Text
image	Yes	File

Note:

- For multipart, send either `attendanceFlag` or `flag`.

GET `/api/mobile/attendance/history`

Use this API to show attendance history.

Headers:

Authorization: Bearer <accessToken>

Query options:

Parameter	Required	Description
employeeId	Yes	Employee ID
date	No	Single date in `yyyy-MM-dd` format
fromDate	No	Start date in `yyyy-MM-dd` format
toDate	No	End date in `yyyy-MM-dd` format

Examples:

```
GET /api/mobile/attendance/history?employeeId=20&date=2026-07-06
GET /api/mobile/attendance/history?employeeId=20&fromDate=2026-07-01&toDate=2026-07-06
```

Success response:

```
{
  "success": true,
  "message": "Attendance history fetched successfully.",
  "employeeId": 20,
  "fromDate": "2026-07-01",
  "toDate": "2026-07-06",
  "attendanceHistory": [
    {
      "attendanceId": 501,
      "attendanceDate": "2026-07-06",
      "checkInTime": "2026-07-06T09:35:00",
      "checkOutTime": "2026-07-06T18:10:00",
      "inTime": "09:35",
      "outTime": "18:10",
      "totalHours": "08:35",
      "status": "PRESENT",
      "attendanceSource": "MOBILE_APP",
      "checkedIn": true,
      "checkedOut": true
    }
  ]
}
```

Common attendance errors:

Code	Meaning
---	---
`IMAGE_REQUIRED`	Attendance image is required
`INVALID_IMAGE`	Image data is invalid
`LATITUDE_REQUIRED`	Latitude is missing
`LONGITUDE_REQUIRED`	Longitude is missing
`INVALID_LATITUDE`	Latitude is outside allowed range
`INVALID_LONGITUDE`	Longitude is outside allowed range
`INVALID_ATTENDANCE_FLAG`	Attendance flag is invalid
`ATTENDANCE_FLAG_REQUIRED`	Attendance flag is required

9. Mobile App Implementation Notes

Android and iOS app should follow these rules:

- Use HTTPS only.
- Store bearer token securely in platform secure storage.
- Always send `Authorization: Bearer <accessToken>` after login.
- Use `empId` from login response as `employeeId`.
- After contact update, replace the old token with the new `accessToken` returned by the API.
- Do not hardcode location radius in the app. Use the radius returned by mapped locations API.
- For image APIs, prefer multipart upload when possible. Use JSON Base64 only when multipart is not suitable.
- Do not store passwords in the app.
- For forgot password without login, use a separate OTP/token API. Do not use the authenticated reset endpoint.

10. Suggested Future APIs

These APIs are not part of the current implementation but are recommended for a complete mobile app flow.

Device Registration

Recommended endpoint:

POST /api/mobile/devices

Purpose:

- Store Android/iOS device details.
- Store FCM/APNS push token.
- Track app version and device login.

Recommended table:

mobile_user_device

Recommended columns:

id
user_id
employee_id
device_id
platform
push_token
app_version
os_version
is_active
last_login_at
created_at
updated_at

Forgot Password With OTP

Recommended endpoints:

POST /api/mobile/auth/password/forgot
POST /api/mobile/auth/password/verify-otp
POST /api/mobile/auth/password/reset

Recommended table:

mobile_password_reset_token

Recommended columns:

id
user_id
otp_hash
expires_at
attempt_count
is_verified
consumed_at
created_at
updated_at